

Data Obfuscation: Masking and Anonymization

ISC2 CCSP: Certified Cloud Security Professional | Domain 2: Cloud Data Security

1. The Data Copy Problem

Consider how much sensitive information your organisation holds that does not need to exist in the form it is currently stored. Customer names and email addresses sitting in a testing database. Real patient identifiers flowing through an analytics pipeline. Live Social Security numbers accessible to thirty engineers in a development environment. The data arrived in those places because copying everything was simpler than deciding what to protect.

Every unnecessary copy of sensitive data is a potential breach point. Data obfuscation addresses this at the source: instead of trying to harden every system that touches sensitive data, make the data itself useless to an attacker in most contexts. This is a fundamentally more scalable approach to data protection than perimeter security alone.

2. What Data Obfuscation Is

Data obfuscation is the discipline of reducing the intelligence value of data to an attacker without destroying its usefulness to the business. The data must still work for legitimate purposes — testing, analytics, reporting — while becoming worthless if exfiltrated.

The CCSP examination focuses on three primary obfuscation techniques:

Technique	Reversible?	Primary Purpose	Exam Focus
Data Masking	No (static) / In-query (dynamic)	Protect sensitive data in non-production environments	High — static vs. dynamic masking distinction
Anonymization	No (intended permanent)	Remove all identifying information permanently	High — re-identification risk and GDPR implications
Pseudonymization	Yes (with mapping)	Replace identifiers while preserving ability to re-link	High — GDPR risk reduction, middle ground
Differential Privacy	N/A (statistical noise)	Publish aggregate statistics without individual exposure	Medium — Apple iOS use case

3. Static Data Masking

Static data masking takes a production dataset, runs a transformation, and produces a sanitised copy for use in lower-trust environments such as development, quality assurance, or third-party testing. The original production data remains unchanged. The copy is what goes to the team that needs realistic data structures without exposure to real customer records.

Key characteristics of static masking:

- Performed once, producing a separate sanitised dataset.
- The masked values are realistic but fictitious — a masked customer name is replaced with a different name in the same format; a masked Social Security number is replaced with a nine-digit number that corresponds to no real person.
- The original values are typically discarded from the copy — recovery is not the goal.
- This is the standard approach most regulators and auditors expect when asking how an organisation manages production data in non-production environments.

Key Point: Static masking produces a separate, permanently sanitised copy. The original remains intact in production. The copy goes to lower-trust environments. This is a one-time, batch transformation — not a real-time operation.

4. Dynamic Data Masking

Dynamic data masking works in real time without creating a separate copy. It intercepts database queries and applies masking rules based on the role or permission level of the requester. The underlying database is never changed — the masking layer filters what each requester sees based on their entitlements.

A practical example: in a customer service platform, a representative querying an account record might see only the last four digits of a payment card number. A billing system with full authorisation sees the complete number. Both are querying the same database — the masking layer determines the view. Microsoft Azure SQL Database and Salesforce offer native dynamic data masking capabilities configurable at the column level without modifying application code.

Characteristic	Static Masking	Dynamic Masking
Creates a separate copy	Yes	No — same database, filtered view
Original data modified	No	No — masking layer sits in between
Real-time operation	No — batch process	Yes — per-query filtering
Use case	Dev/QA environments	Role-based access control in production
Recovery of original	Not from copy (original in prod)	Always available to authorised roles

5. Anonymization: The Permanent Removal Goal

Anonymization goes further in intent than masking. The goal is to remove all personally identifying information from a dataset so that no individual can be traced — even when the dataset is combined with other available information. True anonymization is intended to be permanent and irreversible.

Unlike masking, which preserves the ability to work with original values when authorised, anonymization is a one-way transformation. Once properly anonymized, data falls outside the scope of most data

protection regulations, including the GDPR, because it no longer relates to an identifiable person. This is a significant regulatory incentive: anonymous data can be shared, sold, or published without the compliance overhead that accompanies personal data.

The critical qualifier is 'properly.' Genuine anonymization is harder to achieve than it appears.

6. The Re-identification Problem

Re-identification attacks have repeatedly demonstrated that information believed to be anonymous can be traced back to individuals when combined with other datasets. Removing names and obvious identifiers is rarely sufficient.

Real-World Incident — Netflix Prize Dataset (2006–2008): Netflix published the anonymized movie rating records of approximately 500,000 subscribers for a machine learning competition. Netflix removed names and account numbers. Within two years, researchers Narayanan and Shmatikoff demonstrated that a significant proportion of records could be linked back to specific individuals by cross-referencing viewing patterns with publicly available data on the Internet Movie Database. The combination of film ratings, timestamps, and titles was distinctive enough to reconstruct identities. The data was not as anonymous as it appeared — a landmark demonstration that anonymization is not simply the removal of obvious fields.

The lesson from the Netflix case is that anonymization must be designed with re-identification resistance in mind, not just field removal. The more dimensions a dataset has — ratings, locations, timestamps, purchase patterns — the more likely the combination uniquely identifies an individual even after obvious identifiers are stripped.

7. Pseudonymization: The Safer Middle Ground

Pseudonymization replaces identifying values with pseudonyms — typically randomly generated identifiers — while keeping the mapping between pseudonym and real identity stored separately in a controlled, access-restricted location. The operational data uses only pseudonyms. The mapping file is the sensitive asset.

Why this matters:

- A breach of the operational data alone does not expose real identities — the attacker gets pseudonyms, not names or identifiers.
- Authorised operations — such as linking records from multiple systems, or reverting to real identity for a specific regulatory requirement — remain possible via the mapping.
- GDPR explicitly recognises pseudonymization as a meaningful risk-reduction measure and treats it as a good-faith step toward compliance.

Critically, GDPR does not exempt pseudonymized data from the regulation entirely. Re-identification remains possible if both the pseudonymized dataset and the mapping are obtained. Pseudonymized data is still personal data under GDPR — it simply carries lower risk than unprotected personal data.

8. Differential Privacy: Mathematical Guarantees

Differential privacy is a more rigorous technique designed for scenarios where aggregate statistics need to be published or shared externally. The approach adds carefully calibrated statistical noise to query results so that no individual record has a measurable effect on the published output.

Real-World Incident — Apple iOS and Differential Privacy (2016–present): Apple has applied differential privacy in iOS to gather population-level insights on emoji usage, typing patterns, and other behavioural data across hundreds of millions of devices. The technique adds mathematical noise calibrated so that no individual user's specific behaviour is recoverable from the aggregated statistics. Apple collects useful patterns for keyboard and feature improvement without any individual user's precise behaviour being extractable. This is particularly relevant for cloud-based analytics platforms that expose query results to parties who should not access the underlying records.

Differential privacy provides a formal, mathematically provable privacy guarantee. The trade-off is accuracy: the noise added to protect individuals reduces the precision of aggregate statistics. The calibration of how much noise to add — the privacy budget — is a technical judgment call balancing privacy protection against analytical utility.

9. The Masking vs. Anonymization Confusion

Many organisations treat data masking and anonymization as though they provide equivalent protection, or assume that masking a production copy satisfies their privacy obligations across the board. The distinctions matter:

Question	Static Masking	Anonymization	Pseudonymization
Is the original value recoverable?	No (from copy), Yes (in prod)	No (intended never)	Yes (via mapping)
Does it remove re-identification risk?	Partial — depends on design	Intended yes — but difficult in practice	No — risk if mapping also obtained
Is it subject to GDPR?	Yes — original is personal data	No — if properly done	Yes — still personal data
Primary use case	Dev/test environments	Publishing datasets externally	Analytics requiring re-linkage

The CCSP exam tests whether you understand the difference between removing a field from a dataset in isolation and removing the ability to trace that data to a person when combined with any other available dataset. Those are not the same thing, and the Netflix Prize case is the canonical illustration.

10. Choosing the Right Technique

The approach should match the use case:

- **Business needs to recover original values:** Use pseudonymization. Keep the mapping strictly controlled.

- **Data goes to third-party analytics without individual-level detail:** Anonymization or differential privacy may be sufficient.
- **Development or testing environment needs realistic data structures:** Static masking — no live production data, ever.
- **Different users need different views of the same production data:** Dynamic masking, configured at the column level by role.
- **Population-level statistics need to be published externally:** Differential privacy with a calibrated noise level.

No development or testing environment should ever receive live production data without static masking applied first. This is both a security principle and, in many jurisdictions, a legal requirement.

11. Key Terms Glossary

Term	Definition
Data obfuscation	Reducing the intelligence value of data to an attacker without eliminating its usefulness to the business
Static data masking	Batch transformation of a dataset that replaces sensitive values with realistic fictions; produces a permanent sanitised copy
Dynamic data masking	Real-time interception of database queries that applies masking rules based on the requester's role; no copy created
Anonymization	Intended-permanent removal of all identifying information so no individual can be traced, even with external data
Re-identification attack	Using external datasets to link supposedly anonymous records back to real individuals
Pseudonymization	Replacing identifiers with pseudonyms while storing the mapping separately; allows re-linkage by authorised parties
Differential privacy	Adding calibrated statistical noise to query results so no individual record measurably affects published output
Privacy budget	The calibration of how much noise differential privacy adds, balancing privacy protection against analytical utility
GDPR	EU regulation governing personal data; recognises pseudonymization as a risk-reduction step but does not exempt it
Rainbow table attack	Using a precomputed table of hash values to reverse engineer passwords; defeated by salting in hashing and irrelevant in masking context

12. Quick Revision Checklist

- Data obfuscation reduces attacker intelligence value without destroying business utility.
- Static masking: batch process, produces sanitised copy, original unchanged in production.
- Dynamic masking: real-time, role-based filtering, no separate copy, same underlying database.
- Anonymization: intended permanent, irreversible, falls outside GDPR scope if genuinely done.
- Re-identification is the key risk with anonymization — removing obvious fields is not enough.

- Netflix Prize (2006-2008): classic proof that anonymized datasets can be de-anonymized via cross-referencing.
- Pseudonymization: replaces identifiers with pseudonyms; mapping stored separately; still GDPR-regulated.
- GDPR recognises pseudonymization as a good-faith risk reduction but does not exempt pseudonymized data.
- Differential privacy: adds calibrated noise to aggregates; Apple iOS uses this for behavioural telemetry.
- No development or testing environment should ever receive unmasked live production data.
- Match the technique to the use case: recovery needed → pseudonymize; external publication → anonymize/differential privacy; dev/test → static mask; role-based production views → dynamic mask.

20 Exam-Based MCQs — Data Obfuscation

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. What is the PRIMARY distinction between static data masking and dynamic data masking?

- A) Static masking is reversible; dynamic masking is permanent
- B) Static masking produces a separate sanitised copy; dynamic masking filters query results in real time without creating a copy
- C) Static masking applies to production databases; dynamic masking applies to backups
- D) Dynamic masking encrypts data at rest; static masking encrypts data in transit

Answer: B **Explanation:** B is correct. Static masking runs a batch transformation that produces a permanent sanitised copy; the original production data remains unchanged. Dynamic masking intercepts queries in real time and applies role-based filtering; the underlying database is never modified and no copy is created. A) Neither type is reversible in isolation; the original is always in the production system. C) Static masking is specifically for non-production (dev/test) copies; dynamic masking is used in production environments. D) Neither masking type is an encryption mechanism.

Q2. Which outcome would make data EXEMPT from GDPR obligations?

- A) Applying dynamic data masking so that low-privilege users cannot see full field values
- B) Pseudonymizing the data and storing the mapping in a separate controlled system
- C) Genuinely anonymizing the data so that no individual can be identified, even with external data
- D) Encrypting the data with AES-256 and storing the key in a hardware security module

Answer: C **Explanation:** C is correct. GDPR applies to personal data — information relating to an identifiable person. Genuine anonymization, where re-identification is not possible even with external datasets, takes the data outside GDPR's scope. A) Dynamic masking restricts visibility but the data remains personal data in the underlying database. B) Pseudonymized data is still personal data under GDPR because re-identification remains possible via the mapping. D) Encryption protects confidentiality but the data is still

personal data; GDPR continues to apply.

Q3. Scenario: A data analytics team at a healthcare insurer wants to train a machine learning model on patient records to predict hospital readmission risk. The team proposes removing patient names, dates of birth, and Social Security numbers from the training dataset and treating the result as anonymous. What is the PRIMARY risk with this approach?

- A) The dataset will be too small to train a meaningful model once identifiers are removed
- B) Removing obvious identifiers is insufficient to prevent re-identification when the dataset is combined with other available information
- C) Machine learning models cannot be trained on medical data without full patient identifiers
- D) The approach violates HIPAA because masking is not an approved de-identification method

Answer: B **Explanation:** B is correct. The Netflix Prize case demonstrated that removing obvious identifiers (names, account numbers) does not guarantee anonymization when the remaining fields — diagnoses, timestamps, admission patterns, demographics — are distinctive enough to re-identify individuals through cross-referencing with external datasets. A) Removing identifiers does not reduce dataset size; the records remain, just with those fields removed. C) Models are routinely trained on de-identified or synthetic medical data. D) HIPAA does recognise de-identification methods; the issue here is whether the proposed approach achieves genuine de-identification.

Q4. An organisation deploys a system where customer service representatives see only the last four digits of customer payment card numbers, while the billing system sees complete card numbers — all from the same underlying database. Which technique is in use?

- A) Static data masking
- B) Tokenization
- C) Dynamic data masking
- D) Pseudonymization

Answer: C **Explanation:** C is correct. Dynamic data masking intercepts queries and applies role-based filtering in real time: different users see different views of the same underlying data without a separate copy being created. A) Static masking produces a separate sanitised copy; it does not support showing different views to different users of the same system. B) Tokenization replaces the sensitive value with a token stored in a vault; the original is not visible to any user querying the same database. D) Pseudonymization replaces identifiers with pseudonyms across the dataset; it does not support role-based field visibility.

Q5. Scenario: A financial services company is preparing a dataset of anonymized customer transaction records for release to academic researchers studying spending patterns. The legal team is concerned about re-identification risk. The dataset includes transaction amounts, merchant categories, timestamps, and geographic region codes for approximately 2 million customers. Which technique provides the STRONGEST protection against re-identification while preserving the analytical value of the dataset?

- A) Remove merchant category and geographic region from the dataset
- B) Apply differential privacy, adding calibrated noise to query results so no individual transaction measurably affects published statistics
- C) Replace customer IDs with random pseudonyms and store the mapping internally
- D) Apply static data masking to the transaction amounts

Answer: B **Explanation:** B is correct. Differential privacy provides a formal, mathematically provable privacy guarantee at the individual level while preserving population-level statistical utility. It is specifically designed for releasing aggregate statistics to external parties without individual-record exposure. A) Removing fields reduces re-identification risk but does not eliminate it; the remaining fields may still be distinctive enough to identify individuals. C) Pseudonymization still leaves individuals identifiable via transaction patterns; it reduces risk but does not provide the mathematical guarantee of differential privacy. D) Masking transaction amounts reduces utility significantly and does not address re-identification through transaction patterns and timestamps.

Q6. GDPR recognises pseudonymization as a privacy-protective measure. What does this recognition specifically mean in practice?

- A) Pseudonymized data is fully exempt from GDPR because it is no longer personal data
- B) Pseudonymization is recognised as a risk-reduction measure that does not exempt the data from GDPR but demonstrates good-faith compliance
- C) GDPR requires pseudonymization for all personal data stored in cloud environments
- D) Pseudonymized data can be freely shared with third parties without a data processing agreement

Answer: B **Explanation:** B is correct. GDPR Article 4(5) defines pseudonymization, and Recital 28 encourages it as a risk-reduction measure. However, pseudonymized data is still considered personal data because re-identification remains possible if the mapping is obtained. GDPR continues to apply; the recognition reduces some regulatory burden but does not remove the regulation's reach. A) Pseudonymized data is still personal data under GDPR. C) GDPR encourages but does not mandate pseudonymization. D) Pseudonymized data remains subject to GDPR data transfer and processing requirements.

Q7. Scenario: A software development team requests a copy of the production customer database to use in load testing a new application version. The production database contains names, email addresses, payment card numbers, and transaction history for 5 million customers. What is the MOST appropriate data handling approach for this request?

- A) Provide the full production database with access restricted to the development team's VPN
- B) Provide a subset of 10,000 randomly selected records from production
- C) Apply static data masking to create a sanitised copy with realistic but fictitious values before providing it to the team
- D) Provide the production database encrypted at rest with a key the team can access

Answer: C **Explanation:** C is correct. Static masking produces a sanitised copy where sensitive values are

replaced with realistic fictions. The development team gets accurate data structures and volume without exposure to real customer records. A) VPN access controls do not change the fact that real customer data is in an environment not designed for it; a breach or misconfiguration exposes real records. B) A subset still contains real data — the same risk applies, just to fewer records. D) Encryption at rest protects against storage-level breach but not against the development team (who have the key) mishandling or leaking the data.

Q8. Which statement about the Netflix Prize dataset case (2006-2008) is MOST relevant to cloud data security practice?

- A) It demonstrated that streaming services should not participate in machine learning competitions
- B) It proved that anonymization is impossible and organisations should not attempt it
- C) It illustrated that removing obvious identifiers is insufficient — re-identification can occur through cross-referencing distinctive patterns with external datasets
- D) It showed that SHA-1 hashing of datasets is inadequate for privacy protection

Answer: C **Explanation:** C is correct. The Netflix case proved that film ratings, timestamps, and viewing patterns were distinctive enough to re-identify specific subscribers even after names and account numbers were removed — by cross-referencing with public IMDB data. A) The lesson is about re-identification risk in dataset design, not about competition participation. B) The lesson is that naive anonymization fails; properly designed anonymization with re-identification resistance (like differential privacy) remains a valid goal. D) SHA-1 hashing played no role in the Netflix case; this is irrelevant.

Q9. Apple's use of differential privacy in iOS is BEST described as which of the following?

- A) Encrypting telemetry data before transmission so Apple cannot read individual records
- B) Adding calibrated statistical noise to behavioural data so no individual user's behaviour is recoverable from aggregated statistics
- C) Pseudonymizing device identifiers before sending analytics to Apple servers
- D) Applying static masking to usage logs before they are processed by machine learning models

Answer: B **Explanation:** B is correct. Apple's differential privacy implementation adds mathematically calibrated noise to data before it leaves the device, so the aggregate statistics Apple receives are useful for improving features (keyboard predictions, emoji suggestions) while no individual user's specific behaviour is recoverable from those aggregates. A) Encryption would allow Apple to decrypt and read individual records with the key; differential privacy provides a stronger privacy guarantee. C) Pseudonymization replaces identifiers but the behavioural patterns themselves would remain; differential privacy adds noise to the patterns. D) Static masking produces a sanitised copy; differential privacy operates on statistical query outputs, not on a copied dataset.

Q10. What is the CRITICAL operational requirement that distinguishes pseudonymization from anonymization?

- A) Pseudonymization requires more computational resources than anonymization

- B) Pseudonymization maintains a mapping between pseudonyms and real identities in a separate controlled location, making re-linkage possible for authorised parties
- C) Pseudonymization is a real-time process while anonymization is a batch process
- D) Pseudonymization is only applicable to structured databases; anonymization works on unstructured data

Answer: B **Explanation:** B is correct. The defining characteristic of pseudonymization is the retained mapping — kept separately and strictly controlled — that allows authorised parties to reverse the pseudonym to the real identity when required (for example, to fulfil a regulatory request, complete a transaction, or link records across systems). Without the mapping, you have anonymization. A) Computational resource requirements are not the distinguishing characteristic. C) Neither is exclusively real-time or batch; both can be implemented either way. D) Both techniques apply to structured and unstructured data.

Q11. Scenario: A cloud security architect is reviewing the data protection strategy for a SaaS platform that stores employee HR records including names, tax identifiers, salary information, and performance ratings. The platform must support payroll processing (which needs real values) but also provide anonymized reporting to the board on compensation trends. Which combination of techniques BEST addresses both requirements?

- A) Static masking for payroll processing; differential privacy for board reporting
- B) Pseudonymization for payroll processing (maintaining the mapping); differential privacy for board reporting (aggregate statistics without individual exposure)
- C) Anonymization for all data; restore real values from backup when payroll runs
- D) Dynamic masking for payroll; static masking for board reporting

Answer: B **Explanation:** B is correct. Payroll processing requires access to real values (salary, tax identifiers) — pseudonymization with a controlled mapping allows this for authorised payroll systems while protecting the data in transit and at rest. Board reporting needs aggregate statistics (average compensation by level, trend analysis) without individual exposure — differential privacy provides population-level insights with a mathematical privacy guarantee. A) Static masking replaces values with fictions; payroll cannot run on fictitious salary figures. C) Anonymization is irreversible; payroll cannot run on anonymized data. D) Dynamic masking limits visibility but the underlying real values remain accessible to anyone with sufficient permissions; differential privacy provides stronger protection for aggregate reporting.

Q12. A data engineer proposes using dynamic data masking in a cloud data warehouse to meet GDPR requirements, arguing that since low-privilege analysts cannot see full personal data values, the organisation is GDPR compliant. What is the PRIMARY flaw in this argument?

- A) Dynamic masking is not a recognised privacy technique under GDPR
- B) Dynamic masking controls visibility but does not change the fact that unmasked personal data exists in the database and remains subject to all GDPR obligations
- C) GDPR requires static masking, not dynamic masking, for data warehouse environments
- D) Dynamic masking is only compliant if combined with AES-256 encryption

Answer: B **Explanation:** B is correct. Dynamic masking is a visibility control — it changes what users see in query results but does not alter the underlying data. The database still contains personal data. GDPR obligations (data subject rights, retention limits, breach notification, cross-border transfer rules) apply to the organisation based on what data it holds, not what individual users can see. A) Dynamic masking is a legitimate technique; GDPR does not enumerate specific technical controls but assesses adequacy. C) GDPR does not specify static vs. dynamic masking. D) Encryption is complementary but combining it with dynamic masking does not resolve the GDPR compliance argument.

Q13. Which of the following is the BEST example of a situation where static data masking is the appropriate choice?

- A) A customer service representative needs to verify the last four digits of a customer's account number during a live call
- B) A quality assurance team needs a copy of production customer records to test a new checkout flow in a staging environment
- C) A data scientist needs to run aggregate queries on production sales data without seeing individual customer names
- D) A security team needs to audit who has accessed sensitive records in the last 30 days

Answer: B **Explanation:** B is correct. Static masking is specifically designed for this use case: creating a sanitised copy of production data for non-production environments. Real customer records have no business being in a staging environment. A) This is a dynamic masking use case — the same production database is accessed but visibility is role-based. C) This is a differential privacy or dynamic masking use case — aggregate queries on production data without individual exposure. D) This is an access control and audit logging use case, unrelated to masking.

Q14. *Scenario:* A health insurer is responding to a regulator's request for a dataset demonstrating that their AI-driven claims processing model does not discriminate by patient demographic. The insurer wants to share the dataset with the regulator without exposing individual patient records. Which approach BEST balances regulatory transparency with patient privacy?

- A) Encrypt the dataset and share the decryption key with the regulator under NDA
- B) Share the full dataset with names replaced by pseudonyms
- C) Apply differential privacy to generate aggregate statistical outputs that demonstrate model behaviour across demographic groups without exposing individual records
- D) Apply static masking to replace all patient identifiers and share the resulting copy

Answer: C **Explanation:** C is correct. Differential privacy allows sharing aggregate statistics — model performance by demographic group, decision rate distributions — with a mathematical guarantee that no individual record is exposed. The regulator gets the transparency they need without access to personal health data. A) Sharing the key defeats the purpose of encryption; the regulator would then have access to all individual records. B) Pseudonymized data is still personal data; sharing it with the regulator creates data transfer obligations and exposes individual-level records. D) Static masking with all identifiers removed may work, but differential privacy provides a stronger formal guarantee and is more appropriate when the

goal is statistical analysis of model behaviour.

Q15. Which of the following statements about anonymization is MOST accurate?

- A) Anonymization is straightforward to achieve by removing names, dates of birth, and government identifiers from a dataset
- B) Anonymization requires formal testing for re-identification resistance using available external datasets, not just removal of obvious identifying fields
- C) Anonymization is equivalent to pseudonymization; both permanently prevent re-identification
- D) Anonymization of medical data is not possible due to the inherent uniqueness of health records

Answer: B **Explanation:** B is correct. The Netflix Prize case proved that removing obvious identifiers is not sufficient. Genuine anonymization must be tested against the realistic risk of re-identification using datasets that could plausibly be combined with the published data. A) Removing obvious fields is the starting point, not the conclusion, of anonymization. C) Pseudonymization explicitly retains the ability to re-link; it is not equivalent to anonymization. D) Medical data anonymization is achievable with proper design — HIPAA's Safe Harbor and Expert Determination methods are recognised frameworks.

Q16. A software development team is building a new feature and requests access to production customer email addresses for integration testing. The security team approves providing a dataset where each email address is replaced with a randomly generated address in the same format (e.g., random@randomdomain.com). Which technique is being applied?

- A) Tokenization
- B) Pseudonymization
- C) Static data masking
- D) Dynamic data masking

Answer: C **Explanation:** C is correct. Static data masking replaces sensitive values with realistic but fictitious substitutes in a separate copy intended for a non-production environment. The masked email addresses preserve the format without corresponding to real people. A) Tokenization replaces values with random tokens stored in a vault; the token can be reversed via vault lookup — the scenario describes no vault. B) Pseudonymization replaces identifiers with pseudonyms while maintaining a mapping for re-linkage; here the replacement is intended to be permanent and no mapping is maintained. D) Dynamic masking applies in real time to query results from a live database; here a separate copy is being provided.

Q17. *Scenario:* An organisation discovers that a third-party data analytics vendor has cross-referenced their published 'anonymized' user behaviour dataset with publicly available social media data and successfully identified the real identities of a significant proportion of users. The organisation's legal team argues the breach cannot be their fault because the dataset was anonymized. What is the MOST accurate assessment of the organisation's position?

- A) The organisation is correct — once anonymized, data breaches are not the publishing organisation's responsibility

- B) The organisation bears responsibility because publishing data without adequate re-identification resistance testing constitutes inadequate privacy protection
- C) The vendor is solely responsible because the re-identification was performed using external data not provided by the organisation
- D) The organisation is protected because differential privacy was used in the anonymization process

Answer: B **Explanation:** B is correct. Regulatory frameworks including GDPR place the responsibility on the data controller to ensure that anonymization is genuine — meaning re-identification must not be reasonably possible given available external data. Publishing a dataset without testing its re-identification resistance against realistic external datasets fails this standard. A) The 'we called it anonymous' defence does not satisfy GDPR or most privacy frameworks; the test is whether re-identification is possible in practice. C) The organisation published the data; the re-identification was foreseeable. D) The scenario does not state differential privacy was used, and this option fabricates an unrelated defence.

Q18. Which of the following scenarios represents an appropriate use of pseudonymization rather than anonymization?

- A) Publishing a dataset of patient outcomes to a medical journal for peer review
- B) Providing a sanitised database copy to a third-party QA vendor for testing
- C) Processing customer loyalty records where individual customers may need to be re-identified for personalised offers or dispute resolution
- D) Generating aggregate statistics on employee compensation trends for board reporting

Answer: C **Explanation:** C is correct. Pseudonymization is the right choice when the business requires the ability to re-link data to real individuals for authorised purposes — loyalty programme personalisation, dispute resolution, regulatory compliance. The mapping is controlled and available when needed. A) Publishing to a journal requires irreversible anonymization (or consent); pseudonymization still carries re-identification risk if the mapping is ever exposed. B) QA testing is a static masking use case — the replacement should be permanent fictions, not pseudonyms with a mapping. D) Board reporting on aggregate trends is a differential privacy or anonymization use case; individual re-linkage is not needed.

Q19. What does the term 'privacy budget' refer to in the context of differential privacy?

- A) The financial cost of implementing a differential privacy solution
- B) The calibration of how much statistical noise is added to query results, balancing privacy protection against analytical accuracy
- C) The number of queries an analyst is permitted to run against a differential-privacy-protected dataset
- D) The regulatory budget allocated to GDPR compliance activities

Answer: B **Explanation:** B is correct. The privacy budget (often denoted epsilon in academic literature) controls the trade-off: a smaller budget (more noise) provides stronger privacy protection but reduces the accuracy of aggregate statistics; a larger budget (less noise) improves accuracy but weakens privacy guarantees. A) The privacy budget is a technical parameter, not a financial concept. C) Query counting is

one mechanism for managing privacy budget consumption, but the budget itself is the noise calibration parameter. D) This is an unrelated use of the word 'budget.'

Q20. Scenario: A cloud platform provider wants to improve its autocomplete and spell-check features using typing data from users across 200 million devices. The legal team requires that no individual user's specific typing patterns be recoverable from the data the company collects. The engineering team proposes collecting anonymized typing logs from each device. Which approach BEST satisfies both the product improvement goal and the legal requirement?

- A) Collect full typing logs and pseudonymize them by replacing device IDs with random tokens before storage
- B) Apply static masking to remove device identifiers from typing logs before uploading them to the cloud
- C) Implement differential privacy on-device, adding calibrated noise before any data leaves the device, and aggregate the noisy statistics server-side
- D) Encrypt typing logs at rest with a key the company does not hold

Answer: C **Explanation:** C is correct. This is precisely the Apple iOS differential privacy model. By adding mathematical noise on the device before transmission, individual typing patterns are never recoverable — even by the company — while aggregate statistics (common words, frequent corrections) remain useful for feature improvement. The legal requirement is met by design. A) Pseudonymization replaces identifiers but the typing patterns themselves remain; a motivated party could still analyse the patterns and potentially link them to individuals. B) Static masking removes identifiers but the typing pattern data remains and is uploaded; the company still receives individual-level behavioural data. D) Client-side encryption with a key the company does not hold means the company also cannot use the data for product improvement — it defeats the stated goal.